

VirtuEx 시스템 감사 보고서 (21차)

VirtuEx System Audit Report (21st)

- 감사일: 2026-03-20
- 감사 범위: API 보안, 입력 검증, 에러 처리, 인증/인가, DB 무결성, 서비스 간 통신, 로깅/모니터링, 프론트엔드 보안, HTTP 보안 헤더, WebSocket 보안, IDOR, 감사 로깅
- 감사 방법: 전체 소스 코드 정적 분석 + API 흐름 추적 + 보안 취약점 패턴 매칭 + 21차 강화 기준 적용
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 본 보고서는 20차 대비 강화된 기준으로 작성되었으며, 발견 사항만 기록합니다

이전 감사 대비 수정 현황 (20차 → 21차)

이전 이슈	상태	비고
[SEC-C-01] JWT 액세스 토큰 sessionStorage 저장	미수정	여전히 sessionStorage에 저장, 마이그레이션 계획(Step 1~4) 명시되어 있으나 미수행
[VAL-M-01] 채팅 메시지 content 길 이 제한 미검증	수정됨	SendMessageDto에 @MaxLength(5000) 적용 확인
[VAL-M-02] 주문 수량 프론트엔드 소 수점 자릿수 미제한	미수정	OrderForm.tsx:304에서 직접 입력 시 여전히 소수점 제한 없 음
[VAL-L-01] 입금/출금 금액 음수 입력 방지 미흡	미수정	amount <= 0 체크는 존재하나 min="0" HTML 속성 미적용
[ERR-M-01] 주문 프로ksi 거래 알림 실 패 시 내부 에러 메시지 로깅	미수정	e.message 로그 노출 유지
[ERR-M-02] 관리자 감사 trades any 타입 사용	미수정	Record<string, any>, (t: any) 등 5개소 유지
[ERR-L-01] 프론트엔드 catch 블록 에 러 무시 패턴	미수정	catch { // Error handled by query client } 패턴 유지
[CSP-M-01] CSP unsafe-inline + strict-dynamic 공존	미수정	동일 설정 유지
[CSP-M-02] CSP connect-src localhost 와일드카드 허용	미수정	http://localhost:* 여전히 포함
[AUTH-M-01] 호가창 엔드포인트 인증 불필요 노출	미수정	GET /api/orders/book/:symbol에 인증 가드 없음
[AUTH-L-01] 공개 포트폴리오 API 보 유 자산 상세 노출	미수정	절대 수량 마스킹 미적용
[SVC-M-01] JwtStrategy localhost 하드코딩	수정됨	configService.getOrThrow<string> ('SERVICE_HOST') 사용 확인
[SVC-L-01] 알림 DB 저장 주문 응답과 동기	미수정	.catch() 패턴 유지, 명시적 분리 미수행

[FE-M-01] RichEditor 이미지 업로드 서버 실패 시 Base64 폴백	미수정	catch { editor.chain().focus().setImage({ src: dataUrl }).run(); } 유지
[FE-L-01] window.confirm 사용	미수정 (비검 증)	확인 불필요 — UI 일관성 이슈
[DI-M-01] displayCurrentPrice 기 반 최대 수량 계산 편차	미수정	portfolio.cashBalance / displayCurrentPrice 계산 유지
[DI-L-01] 커뮤니티 게시물 title 프론트 엔드 maxLength 미제한	수정됨	백엔드 CreatePostDto에 @MaxLength(200) 적용 확인

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 인증/토큰 보안	1	1	0	0	2
B. 입력 검증	0	0	2	1	3
C. 에러 처리/정보 노출	0	0	2	1	3
D. XSS/CSP 방어	0	0	2	0	2
E. 인가/권한 검증	0	1	1	1	3
F. 서비스 간 통신	0	0	1	0	1
G. HTTP 보안 헤더	0	0	1	0	1
H. 감사 로깅	0	1	1	0	2
I. 기타	0	0	2	1	3
합계	1	3	12	4	20

A. 인증/토큰 보안 — 2건

[SEC-C-01] JWT 액세스 토큰 sessionStorage 저장 — XSS 취약점 (Critical, 미수정)

- 현상: JWT 액세스 토큰이 sessionStorage에 저장되어 XSS 공격 시 sessionStorage.getItem('virtuex-auth')로 토큰 탈취 가능. auth.ts 상단에 4단계 마이그레이션 계획이 상세히 문서화되어 있으나 18차부터 지속적으로 미수행. 21차 기준으로 Critical 유지하며, 프로덕션 출시 불가 조건으로 판정
- 위치: frontend/src/stores/auth.ts:89-119
- 영향: XSS 공격 시 토큰 탈취 → 계정 완전 장악, CSP-M-01/CSP-M-02와 결합 시 연쇄 공격 벡터 형성
- 권장: 마이그레이션 계획(Step 1~4) 즉시 실행. 리프레시 토큰은 이미 HttpOnly 쿠키로 관리되므로 액세스 토큰도 동일 방식으로 전환 가능
- 심각도: Critical

[SEC-H-01] CORS allowedHeaders에 x-user-id 포함 — 외부 클라이언트의 userId 조작 가능

- **현상:** API Gateway `main.ts:98` 에서 `CORS allowedHeaders` 에 `'x-user-id'` 가 포함되어 있음. `x-user-id` 는 API Gateway가 JWT에서 추출하여 다운스트림 서비스에 전달하는 내부 서비스 간 헤더이지만, CORS 허용으로 인해 외부 클라이언트가 이 헤더를 직접 설정하여 요청을 보낼 수 있음. 대부분의 프록시 컨트롤러에서 `req.user?.id` 로 JWT에서 추출하지만, 다운스트림 서비스(`portfolio`, `order-engine` 등)는 `x-user-id` 헤더만 신뢰하므로, 프록시 컨트롤러가 실수로 클라이언트 제공 `x-user-id` 를 전달하면 IDOR 취약점 발생
- **위치:** `backend/services/api-gateway/src/main.ts:98`
- **영향:** 향후 코드 변경 시 IDOR 취약점으로 발전할 수 있는 잠재적 위험. 현재는 프록시 컨트롤러가 JWT에서 `userId`를 추출하여 덮어쓰므로 직접적 악용 불가하나, `x-internal-token` 도 `allowedHeaders`에 포함되어 있어 추가 공격 표면 제공
- **권장:** `allowedHeaders` 에서 `x-user-id` 와 `x-internal-token` 을 제거. 이 헤더들은 서비스 간 내부 통신용이므로 외부 클라이언트에서 설정할 수 없어야 함
- **심각도:** High

[VAL-M-01] PlaceOrderDto — quantity/price 형식 검증 부재 (Medium)

[ERR-M-01] 주문 프록시 — 거래 알림 실패 시 내부 에러 메시지 로깅 (Medium, 미수정)

- **현상:** `order-proxy.controller.ts:62` 에서 `sendTradeNotification` 실패 시 `e.message` 를 `Logger.warn`으로 출력. 프로덕션 환경에서 내부 서비스 URL, 인증 토큰 관련 에러가 로그에 노출될 가능성
- **위치:** `backend/services/api-gateway/src/proxy/order-proxy.controller.ts:62`
- **영향:** 로그 수집 시스템에서 민감 정보 노출 가능
- **권장:** 에러 메시지를 일반화하거나 `e.message` 대신 에러 코드만 기록
- **심각도:** Medium

[ERR-M-02] 관리자 감사 trades — any 타입 사용에 의한 타입 안전성 결여 (Medium, 미수정)

- **현상:** `order-proxy.controller.ts:164-176` 에서 `as Record<string, any>` , `(t: any)` , `(u: any)` 등 `any` 타입 5개소 사용. 21차 기준에서는 `portfolio-proxy.controller.ts:42,58,74,90,105` 등에서도 `(req as Record<string, any>).user?.id` 패턴이 반복적으로 사용되어 타입 안전성이 전체적으로 결여
- **위치:** `backend/services/api-gateway/src/proxy/order-proxy.controller.ts:164-176` , `backend/services/api-gateway/src/proxy/portfolio-proxy.controller.ts:42,58,74,90,105,119,134,155,250,273,309,366,385,404`
- **영향:** 예상치 못한 데이터 구조 변경 시 런타임 크래시, 타입 가드 부재로 잘못된 속성 접근 가능
- **권장:** 응답 데이터 인터페이스 정의, `@CurrentUser('id')` `userId: string` 데코레이터 일관 사용
- **심각도:** Medium

[ERR-L-01] 프론트엔드 catch 블록 — 에러 무시 패턴 반복 (Low, 미수정)

- **현상:** `portfolio/page.tsx:99-101,113-115` 에서 `catch { // Error handled by query client }` 패턴으로 에러를 무시. 에러 객체를 참조하지 않아 디버깅 시 원인 추적 어려움
- **위치:** `frontend/src/app/(main)/portfolio/page.tsx:99,113`
- **영향:** 네트워크/서버 에러 원인 파악 지연
- **권장:** 최소한 `catch (e) { console.debug(e); }` 또는 에러 추적 서비스 연동
- **심각도:** Low

D. XSS/CSP 방어 — 2건

[CSP-M-01] CSP script-src — unsafe-inline + strict-dynamic 공존 (Medium, 미수정)

- **현상:** `next.config.ts:9` 에서 프로덕션 CSP `script-src` 가 `'self' 'unsafe-inline' 'strict-dynamic'` 으로 설정. CSP 3.0 지원 브라우저에서 `'unsafe-inline'` 은 무시되지만, CSP 2.0만 지원하는 브라우저에서 인라인 스크립트 실행 허용
- **위치:** `frontend/next.config.ts:9`
- **영향:** CSP 2.0 브라우저에서 XSS 방어력 약화
- **권장:** nonce 기반 CSP로 전환하여 `'unsafe-inline'` 완전 제거
- **심각도:** Medium

[CSP-M-02] CSP connect-src — localhost 와일드카드 허용 (Medium, 미수정)

- **현상:** `next.config.ts:38` 의 CSP `connect-src` 에 `http://localhost:*` 가 포함. 프로덕션 환경에서 XSS 통해 로컬 서비스에 접근할 수 있는 경로 제공
- **위치:** `frontend/next.config.ts:38`
- **영향:** XSS + 로컬 서비스 익스플로잇 체인 가능
- **권장:** 프로덕션 빌드에서 `http://localhost:*` 제거, 환경별 CSP 분리
- **심각도:** Medium

E. 인가/권한 검증 — 3건

[AUTH-H-01] 시장 데이터 및 AI 엔드포인트 — 인증 없이 무제한 접근 + Rate Limit 미적용 (High, 21차 신규)

- **현상:** MarketProxyController 전체(GET /api/market/assets , /prices , /prices/:symbol , /prices/:symbol/history , /prices/:symbol/candlesticks), NewsProxyController 의 GET /api/news , AiProxyController 의 GET /api/ai/signals 및 POST /api/ai/news-summary 에 인증 가드와 엔드포인트 별 Rate Limit이 모두 없음. 글로벌 ThrottlerGuard(분당 100건)만 적용되지만, 자동화된 스크래핑 또는 API 남용에 대한 방어가 부족함. 특히 POST /api/ai/news-summary 는 AI 서비스 호출(30초 타임아웃)을 트리거하므로 자원 소비가 큼
- **위치:** backend/services/api-gateway/src/proxy/market-proxy.controller.ts (전체), backend/services/api-gateway/src/proxy/news-proxy.controller.ts:24-40 , backend/services/api-gateway/src/proxy/ai-proxy.controller.ts:21-30,53-64
- **영향:** 비인증 사용자가 시장 데이터/AI 서비스를 대량 호출하여 서비스 자원 소진 가능, AI 엔드포인트 남용으로 LLM API 비용 증가
- **권장:** (1) AI 엔드포인트에 @UseGuards(JwtAuthGuard) 추가 또는 엔드포인트별 Rate Limit 강화 (@Throttle({ default: { ttl: 60000, limit: 5 } })). (2) 시장 데이터에 IP 기반 Rate Limit 추가 (@Throttle({ default: { ttl: 60000, limit: 30 } }))
- **심각도:** High

[AUTH-M-01] 호가창 엔드포인트 — 인증 불필요 노출 (Medium, 미수정)

- **현상:** GET /api/orders/book/:symbol 에 인증 가드가 없음. 호가창 데이터에 사용자들의 주문 가격/수량이 포함
- **위치:** backend/services/api-gateway/src/proxy/order-proxy.controller.ts:208-218
- **영향:** 비인증 스크래퍼가 호가 데이터를 자동 수집하여 시장 미시구조 분석/조작에 활용
- **권장:** 공개 API 여부 명시적 결정 후 비공개 시 JwtAuthGuard 추가, 공개 결정 시 엔드포인트별 Rate Limit 적용
- **심각도:** Medium

[AUTH-L-01] 공개 포트폴리오 API — 보유 자산 절대 수량 노출 (Low, 미수정)

- **현상:** /api/portfolio/public/:userId 를 통해 다른 사용자의 보유 심볼, 수량, 평균가, 수익률을 정확히 조회 가능
- **위치:** backend/services/api-gateway/src/proxy/portfolio-proxy.controller.ts:222-235
- **영향:** 특정 사용자의 정확한 포지션 크기가 노출되어 의도적 반대매매 가능
- **권장:** 보유 비율(%)만 공개하고 절대 수량은 마스킹
- **심각도:** Low

F. 서비스 간 통신 — 1건

[SVC-M-01] 서비스 간 HTTP 통신 — HTTPS 미적용 (Medium, 21차 신규)

- **현상:** ProxyService.initClients() 에서 모든 내부 서비스 URL이 http://\${host}:\${port} 형태로 생성. Docker 네트워크 또는 K8s 클러스터 내부에서도 서비스 간 통신이 평문 HTTP로 수행됨. INTERNAL_SERVICE_SECRET 이 평문으로 전송되며, 사용자 데이터(userId, 토큰 등)가 네트워크 상에 노출
- **위치:** backend/services/api-gateway/src/proxy/proxy.service.ts:70-77
- **영향:** 같은 네트워크에 있는 공격자가 서비스 간 트래픽을 가로채 내부 시크릿 및 사용자 데이터 탈취 가능
- **권장:** 프로덕션에서 서비스 메시(Istio/Linkerd) mTLS 적용 또는 서비스 간 HTTPS 사용 검토
- **심각도:** Medium

G. HTTP 보안 헤더 — 1건

[HDR-M-01] 백엔드 API 응답 — Permissions-Policy 헤더 미설정 (Medium, 21차 신규)

- **현상:** next.config.ts 에서 X-Frame-Options: DENY , X-Content-Type-Options: nosniff , Strict-Transport-Security , Referrer-Policy 등 주요 보안 헤더가 적용되어 있으나, Permissions-Policy (구 Feature-Policy) 헤더가 누락. 이 헤더가 없으면 페이지에서 카메라, 마이크, 위치정보, payment 등 브라우저 기능을 제한 없이 사용할 수 있어 XSS 공격 시 악용 가능. 추가로 API Gateway의 Helmet 설정 (main.ts:37-55)에서도 Permissions-Policy 가 미설정
 - **위치:** frontend/next.config.ts:32-37 , backend/services/api-gateway/src/main.ts:37-55
 - **영향:** XSS 공격 시 브라우저 민감 API(카메라, 마이크 등) 악용 가능
 - **권장:** Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=() 헤더 추가
 - **심각도:** Medium
-

H. 감사 로깅 — 2건

[AUD-H-01] 관리자 민감 작업 — 감사 로그 미기록 (High, 21차 신규)

- **현상:** 관리자 프록시 컨트롤러에서 사용자 승인(POST /admin/users/:id/approve), 거절(POST /admin/users/:id/reject), 비활성화(POST /admin/users/:id/deactivate), 삭제(DELETE /admin/users/:id), 역할 변경(PATCH /admin/users/:id/role), 계정 잠금 해제(POST /admin/users/:id/unlock) 등 민감한 관리자 작업이 수행될 때, 어느 관리자가 어떤 작업을 수행했는지에 대한 전용 감사 로그가 기록되지 않음. LoggingInterceptor에서 HTTP 요청 메서드/경로/상태코드만 로깅하며, 관리자 식별 정보(userId, IP)와 대상 사용자 정보가 포함되지 않음
- **위치:** backend/services/api-gateway/src/proxy/admin-proxy.controller.ts (전체), backend/services/api-gateway/src/config/logging.interceptor.ts:22-37
- **영향:** 관리자 권한 남용 시 추적 불가, 내부 위협 대응 불가, 규제 준수(금융 감독 등) 요건 미충족
- **권장:** (1) 관리자 작업 전용 감사 로그 테이블 생성 (adminId, action, targetUserId, timestamp, details). (2) LoggingInterceptor에서 관리자 엔드포인트 호출 시 JWT에서 추출한 userId를 포함하여 로깅
- **심각도:** High

[AUD-M-01] 비밀번호 재설정 — 성공/실패 이벤트 로깅 불충분 (Medium, 21차 신규)

- **현상:** AuthService.resetPassword() 에서 비밀번호 재설정 성공 시 logger.log 만 기록. 실패(잘못된 sessionId, 미인증 세션 등)의 경우 UnauthorizedException 만 발생하고 별도 실패 로그가 없음. 비밀번호 재설정 은 계정 탈취의 핵심 경로이므로, IP 주소, 시도 횟수, 세션 ID 등의 컨텍스트와 함께 성공/실패 모두 감사 로그에 기록되어야 함
 - **위치:** backend/services/user-auth/src/application/services/auth.service.ts:668-705
 - **영향:** 비밀번호 재설정 악용 시도 패턴 감지 불가
 - **권장:** 비밀번호 재설정 성공/실패 시 구조화된 감사 이벤트 기록 (userId, sessionId, IP, timestamp, result)
 - **심각도:** Medium
-

I. 기타 — 3건

[FE-M-01] RichEditor 이미지 업로드 — 서버 실패 시 Base64 폴백 유지 (Medium, 미수정)

- **현상:** RichEditor.tsx:144-147 에서 서버 업로드 실패 시 editor.chain().focus().setImage({ src: dataUrl }).run() 으로 Base64 data URL 폴백. 대용량 Base64 데이터가 게시글 HTML에 포함되어 DB에 저장됨
- **위치:** frontend/src/components/ui/RichEditor.tsx:144-147
- **영향:** 서버 불안정 시 DB에 대용량 Base64 저장, 게시글 조회 성능 저하

- **권장:** 서버 업로드 실패 시 사용자 에러 알림 후 이미지 삽입 차단
- **심각도:** Medium

[FE-M-02] 주문 폼 — displayCurrentPrice 기반 최대 수량 계산 편차 (Medium, 미수정)

- **현상:** OrderForm.tsx:321 에서 매수 100% 비율 클릭 시 `maxQty = portfolio.cashBalance / displayCurrentPrice` 로 계산. `displayCurrentPrice` 는 환율 변환이 적용된 표시 가격이므로 반올림 오차로 잔액 부족 에러 발생 가능
- **위치:** frontend/src/components/trading/OrderForm.tsx:320-323
- **영향:** 100% 매수 시 환율 변환 오차가 1% 이상일 경우 주문 실패
- **권장:** 최대 수량 계산을 백엔드 USD 가격 기준으로 수행
- **심각도:** Medium

[MISC-L-01] 공지사항 생성/수정 — Gateway 레벨 AdminRolesGuard 미적용 (Low, 21차 신규)

- **현상:** AnnouncementProxyController 의 컨트롤러 레벨에 `@UseGuards(JwtAuthGuard)` 만 적용. `POST /api/announcements` (생성), `PUT /api/announcements/:id` (수정), `DELETE /api/announcements/:id` (삭제), `POST /api/announcements/:id/pin` (고정) 등 관리자 전용 엔드포인트에 `AdminRolesGuard` 가 없음. user-auth 서비스 내부에서 역할 검증이 되어 있을 수 있으나, Gateway 레벨에서 사전 차단하면 불필요한 서비스 간 호출을 방지하고 방어 심도를 높일 수 있음
- **위치:** backend/services/api-gateway/src/proxy/announcement-proxy.controller.ts:30-31, 120-145, 149-180, 184-198, 202-223
- **영향:** 관리자가 아닌 인증 사용자가 공지사항 생성/수정/삭제 API를 호출하면 user-auth까지 요청이 전달된 후 거부됨 (불필요한 서비스 부하)
- **권장:** 생성/수정/삭제/고정 토큰 엔드포인트에 `AdminRolesGuard` 추가
- **심각도:** Low

종합 평가

21차 시스템 감사에서 총 20건의 이슈를 발견하였습니다. 20차 대비 3건이 수정되었고(SendMessageDto MaxLength 적용, CreatePostDto MaxLength 적용, JwtStrategy SERVICE_HOST 사용), 12건이 미수정 상태입니다. 21차 강화 기준으로 8건의 신규 이슈를 발견하였습니다.

수정 현황

- **수정 3건:** VAL-M-01(채팅 메시지 길이 제한), DI-L-01(게시글 제목 길이 제한), SVC-M-01(JwtStrategy localhost 하드코딩)
- **미수정 12건:** SEC-C-01, VAL-M-02, ERR-M-01/02, ERR-L-01, CSP-M-01/02, AUTH-M-01, AUTH-L-01, SVC-L-01, FE-M-01, DI-M-01

핵심 미수정 이슈

1. **JWT sessionStorage 저장** (SEC-C-01, Critical) — 프로덕션 출시 전 반드시 HttpOnly 쿠키로 전환 필요
2. **CSP unsafe-inline + localhost 와일드카드** (CSP-M-01, CSP-M-02) — SEC-C-01과 결합 시 연쇄 공격 벡터

21차 신규 발견 (강화 기준)

1. **CORS allowedHeaders에 내부 헤더 포함** (SEC-H-01, High) — x-user-id, x-internal-token이 외부 클라이언트에서 설정 가능
2. **시장 데이터/AI 엔드포인트 무제한 접근** (AUTH-H-01, High) — 인증 없이 AI 서비스 대량 호출로 비용 폭증 가능
3. **관리자 민감 작업 감사 로그 미기록** (AUD-H-01, High) — 관리자 권한 남용 추적 불가
4. **서비스 간 HTTP 평문 통신** (SVC-M-01) — INTERNAL_SERVICE_SECRET이 네트워크에 평문 노출
5. **Permissions-Policy 헤더 미설정** (HDR-M-01) — XSS 시 브라우저 민감 API 악용 가능
6. **비밀번호 재설정 감사 로깅 불충분** (AUD-M-01) — 계정 탈취 시도 패턴 감지 불가

- 7. **PlaceOrderDto** 형식 검증 부재 (VAL-M-01) — 극단적 입력값으로 백엔드 연산 비용 증가
- 8. 공지사항 **Gateway AdminRolesGuard** 미적용 (MISC-L-01) — 불필요한 서비스 간 호출 발생

우선 수정 권장 순서

- 1. SEC-C-01 (Critical) — HttpOnly 쿠키 전환
- 2. SEC-H-01 (High) — CORS allowedHeaders에서 내부 헤더 제거
- 3. AUTH-H-01 (High) — AI/시장 데이터 엔드포인트 Rate Limit 강화
- 4. AUD-H-01 (High) — 관리자 감사 로그 시스템 구축
- 5. CSP-M-01 + CSP-M-02 (Medium) — SEC-C-01과 연쇄 공격 가능

본 보고서는 자동 생성된 감사 결과이며, 수정 사항은 포함되지 않습니다.